ai-admin — Tài liệu nghiệp vụ (source of truth)

Nov 2, 2026 · @Chieucasmen

Nguồn chuẩn về **nghiệp vụ ai-admin**. Tổng hợp từ BA gốc (`ba-admin.md` v0.4), code, spec con và ADR — BA v0.4 đã lỗi thời vài chỗ (SSO, cột mới của user/tenant, app_catalog/gói, đối tác), nên tài liệu này mới là bản hợp nhất. Cấu trúc: **Phần A** mô tả toàn bộ nghiệp vụ hiện hành theo mảng; **Phần B** là hướng đang triển khai (cải tổ cấu hình + phân quyền, CR-107). Tham chiếu: ADM-FR/ADM-BR, ADR, CR.

Tổng quan ai-admin

Mục đích. Một nơi quyết định tenant nào, nhóm nào, ai được dùng gì và dùng bao nhiêu — đổi hành vi hệ thống mà không cần deploy.

Admin lo: danh tính (tenant, user, group, đăng nhập, token); phân quyền (3 vai quản trị, feature/entitlement/grant); catalog workflow Dify + command dùng chung; quota & chi phí theo tenant; secret mã hoá; audit + export/import.

Admin KHÔNG lo: chạy workflow, gọi LLM, lưu hội thoại, cấu hình agent — thuộc Agent Hub (nút Test chỉ nhờ Hub chạy thử).

Bốn khối nền tảng: Admin · Agent Hub (điều phối agent, Studio, process engine) · Worker (job, CLI) · Chat App/Extension (người dùng cuối). Trang Quy trình và Nguồn hiển thị trong admin-web nhưng dữ liệu thuộc schema `hub`.

Giả định nền: command, workflow, secret, key Dify dùng chung toàn hệ thống; tenant chỉ được cấp quyền dùng, không tự tạo. Admin và Hub chung một Postgres; admin sở hữu schema `admin`.

Actor: platform_admin · tenant_admin · member · Agent Hub (hệ thống, đọc `hub_ro`) · Builder.

Tenant / công ty

Mục đích. Mỗi tenant là một công ty khách hàng; mọi user và dữ liệu thuộc đúng một tenant. Công ty vận hành cũng là tenant `platform`.

Bảng `admin.tenants`: `key` (mã công ty, unique), `name`, `active`, `max_concurrent_sub`, `settings`, `timezone` (IANA, mặc định `Asia/Ho_Chi_Minh`), `process_runs_max`, `profile`, `default_app`, `version`.

Luật chính: ADM-FR-60 CRUD tenant (không Xoá ở v1, chỉ Khoá; tạo tenant kèm tenant_admin đầu) · ADM-FR-61 khoá tenant thì khoá mọi user + thu hồi refresh token, mở khoá khôi phục trạng thái từng user · ADM-FR-72 timezone (tenant_admin chỉ xem) · ADM-BR-08 mỗi tenant luôn còn ít nhất một tenant_admin active · ADM-BR-09 tenant_admin bị giới hạn theo `tenant_id` (ngoài phạm vi trả 404) · ADM-NFR-06 seed tạo tenant `platform` + feature `core` + platform_admin đầu tiên.

Quyền & cách ly: chỉ platform_admin tạo/sửa/khoá; bảng `tenants` là gốc của RLS. Không đóng băng.

Người dùng, vai hệ thống & đăng nhập

Mục đích. Tài khoản đăng nhập, mỗi tài khoản thuộc đúng một tenant; không có trang tự đăng ký.

Bảng `admin.users`: `tenant_id`, `username` (unique trong tenant), `password_hash` (argon2id), `display_name`, `email`, `role`, `locale`, `theme`, `active`, `must_change_password`, `failed_logins`, `locked_until`, `locked_by_tenant`, `kind` (internal/external), `external_org_id`, `default_app`, `version`. 2FA ở bảng riêng (`user_totp`, `user_backup_codes`; Hub không đọc). Phiên: `refresh_tokens` (xoay vòng, lưu hash).

Vai hệ thống (ADM-BR-05): platform_admin (toàn hệ thống + Studio) · tenant_admin (chỉ tenant mình, không vào Studio) · member (chỉ `/auth/*` + đổi mật khẩu mình).

Luật chính: ADM-FR-01..03 đăng nhập (mã công ty + username + mật khẩu → JWT 15 phút, refresh 30 ngày; refresh xoay vòng; logout thu hồi) · FR-04/05 admin CRUD/khoá user + reset mật khẩu, khoá thì thu hồi token · FR-06 mật khẩu tạm, bắt đổi lần đầu · FR-07 sai 5 lần khoá 15 phút · FR-08 2FA TOTP (bắt buộc cho admin) · FR-63 username duy nhất trong tenant · BR-08 không tự khoá/hạ vai mình, luôn còn ít nhất một platform_admin · NFR-01 argon2id, JWT EdDSA, master key ở env · NFR-04 Admin chết thì Hub vẫn verify được JWT.

Quyền & cách ly: tenant_admin chỉ thao tác user trong tenant mình. Không đóng băng.

Nhóm (groups)

Mục đích. Nhóm user trong một tenant; là đơn vị cấp feature và agent. Không lồng nhóm.

Bảng: `groups` (`tenant_id`, `key`, `name` jsonb vi/en, `description`, `version`; unique `(tenant_id, key)`) · `group_members` (`group_id`, `user_id`, `added_by`, `added_at`).

Luật chính: ADM-FR-62 CRUD group + thêm/bớt thành viên (dán danh sách username thêm hàng loạt) · ADM-FR-37 trang group hiện agent được cấp; tenant_admin cấp agent cho group (ghi `hub.agent_grants` qua API Hub) · ADM-FR-55 `version` chống ghi đè (409) · nhóm `beta-testers` được bảo vệ, feature `beta` chỉ hiện cho nhóm này · user external bị chặn vào group (422 + trigger).

Liên quan RBAC: `enablePack` tự tạo Group vai `<pack>-owner/-editor/-viewer` (xem mục Ứng dụng & gói / Phần B).

Quyền & cách ly: platform_admin & tenant_admin (trong tenant); có RLS. Không đóng băng.

Đối tác (external orgs)

Mục đích. Công ty đối tác nằm trong tenant chủ quản, phục vụ gói Community (CR-102a). *BA v0.4 chưa mô tả; nguồn: ghi-chu.md + spec com-c1-ext-identity.*

Bảng: `admin.external_orgs` (`tenant_id` , `name` , `active` , `created_by` ; không xoá cứng) · `users.kind='external'` + `external_org_id` + `deactivated_at` (FK kép theo tenant).

Luật chính: ADM-FR-74/75 nhận diện user ngoài & công ty đối tác · vai luôn `member` , không vào group, không làm quản lý (422) · vô hiệu công ty ⇒ vô hiệu mọi user của nó (audit từng user) + route 'Mở lại' · `kind` / `external_org_id` bất biến (trigger) · CR-102: xoá tài khoản đối tác = vô hiệu + huỷ kết bạn, giữ bài/bình luận ('đối tác đã rời').

Cách ly: đối tác chỉ thấy gói `community` (EXTERNAL_PACKS = read/write tĩnh); Hub tra qua một cổng duy nhất `ExternalOrgResolver` ; JWT có claim `kind:external` + `xorg` . GĐ1 chỉ Admin chủ quản thêm/khoá; đối tác tự quản là GĐ2 (chưa rõ). Không đóng băng.

Ứng dụng & gói nghiệp vụ

Mục đích. Hai lớp 'ứng dụng': (a) **app web** trong `app_catalog` (switcher 'Ứng dụng' + đích SSO); (b) **gói nghiệp vụ (pack)** nối với app qua `required_feature` . *BA v0.4 chưa mô tả; nguồn: code + ADR-0031 + CR-107.*

`admin.app_catalog` (toàn hệ thống, không RLS): `key` , `name` jsonb, `icon` , `url` , `audience` (all/admin/platform), `required_feature` , `sso` , `sort_order` , `enabled` , `version` . Seed: chat, contracts, community, studio, admin. Đọc qua `GET /me/apps` (lọc theo quyền); ghi `/admin/apps` chỉ platform_admin.

Gói: contracts (Sổ Hợp Tác), community, knowledge. Mỗi gói có 3 feature `<pack>-read/-write/-admin` . **enablePack** bật gói cho tenant: tạo entitlement + 3 Group vai (`<pack>-owner/-editor/-viewer` , nhãn 'Toàn quyền/Nhân viên/Chỉ xem') + 6 grant + agent + NOTIFY Hub (PK-FR-05). API `GET/PUT/DELETE /admin/tenants/:id/packs` .

Nguyên tắc (ADR-0033/CR-107): 'vai theo app' chỉ cho business pack (contracts/community/knowledge); Chat = feature `chat-app` bật/tắt theo tenant; Studio/Admin theo role hệ thống (`required_feature=null`).

Quyền & cách ly: catalog/entitlement/bật gói do platform_admin; Hub đọc thẳng bảng admin. Không đóng băng.

Mô hình quyền: feature → entitlement → grant

Mục đích. Quyết định user dùng được `/cmd` hay gói nào.

Bảng: `features` (`key` , `name` / `description` jsonb, `status` on/off/beta, `version`) · `feature_commands` · `feature_entitlements` (feature × tenant) · `feature_grants` (feature × tenant × group|user) · `config_meta.config_version` .

Luật chính: FR-30 CRUD feature (platform_admin) · FR-31 entitlement cho tenant · FR-32 grant cho group/user trong phạm vi entitlement (UI chỉ cấp cho group; cấp cho user chỉ qua API) · FR-33 kill switch: tắt feature ⇒ command biến khỏi menu ⩽ 5 giây (run đang chạy vẫn xong) · FR-34 `beta` chỉ hiện cho `beta-testers` · FR-35 ma trận feature × group · FR-36 'Kiểm tra quyền'.

Luật cốt lõi: BR-11 dùng được `/cmd` khi lệnh thuộc feature F ∧ F bật (hoặc beta + user trong beta-testers) ∧ F entitlement cho tenant ∧ F grant cho user/group của user · **BR-12** thu hồi entitlement ⇒ grant mất hiệu lực nhưng vẫn giữ · **BR-13** workflow không có quyền riêng (quyền ở command qua feature, hoặc agent qua agent-grant) · **BR-14** tenant không tự tạo command/workflow/secret · FR-53 mỗi lần lưu tăng `config_version` + NOTIFY `config_changed` (Hub nhận ⩽ 5 giây).

Cách ly: entitlement = platform_admin; grant = tenant_admin trong tenant mình; có RLS. CR-107 (vai theo app) là lớp trên, biên dịch xuống feature-grant (ADR-0033). Không đóng băng.

Command & Workflow (catalog — ĐÓNG BĂNG)

Mục đích. Workflow Dify dùng chung; command `/` trỏ tới đúng một workflow.

Bảng: `workflows` (`key` , `name` , `description` 20–400 ký tự, `app_type` , `base_url` , `secret_id` , `input_schema` jsonb, `output_field` , `dify_app_id` , `enabled` , `side_effect` , `version`) · `commands` (`name` , `aliases[]` , `description` , `workflow_id` , `args` , `input_map` , `output` , `mode` sync/async, `timeout_s` , `enabled` , `version`) · `command_names` (tên+alias duy nhất toàn hệ thống) · `tenant_workflow_tools` (công tắc tool theo tenant, Hub chỉ đọc).

Luật chính: FR-10/11 CRUD workflow + nhập input schema tay (mô tả bắt buộc — Hub dùng nguyên văn làm tool cho model) · FR-13 không xoá/tắt workflow đang dùng (hộp xác nhận liệt kê nơi dùng) · FR-14/15 workflow 'Chưa gắn' hợp lệ + cột 'Đang được dùng bởi' · FR-20..22 CRUD command; input map các nguồn `$args.*`, `$selection`, `$page.url/text`, `$attachment`, `$user.id`, `$tenant.id`, hằng · FR-23 nút Test chạy bản nháp qua Hub ('Chạy với tư cách user…') · FR-73 công tắc tool quy trình theo tenant (audit mỗi lần) · BR-01 tên/alias duy nhất (chữ thường/số/-) · BR-02 mỗi command → 1 workflow · BR-06 thực thể tắt vẫn lưu, Hub coi như không tồn tại · BR-04 secret không ra khỏi Admin.

Cách ly & đóng băng: CRUD do platform_admin; catalog toàn cục (không RLS), riêng `tenant_workflow_tools` có RLS. **ĐÓNG BĂNG** (`ADMIN_FROZEN_MODULES`): admin-api workflows/workflow-tools/commands/transfer; admin-web Commands/Workflows/Transfer/Nguồn redirect `/`.

Quota & chi phí

Mục đích. Kiểm soát mức dùng & tính phí theo tenant. Vượt quota KHÔNG chặn — chỉ cảnh báo + tính phần vượt.

Bảng: `tenant_quotas` (`tenant_id`, `feature_id` null=cả tenant, `period` month, `max_runs`, `max_tokens`, `max_usd`, `warn_pct` mặc định 80) · `quota_alerts` · `tenant_daily_limits` (hạn mức NGÀY: uploads/actions/ai_tokens; null = dùng env). Đọc `hub.usage_logs` cho báo cáo.

Luật chính: FR-40 platform_admin đặt quota tháng (run/token/USD), chung hoặc theo feature; mặc định không giới hạn · FR-41 không chặn khi vượt; cảnh báo 80% & 100% cho tenant_admin (email + banner); phần vượt Hub đánh dấu `overage` · FR-42 màn 'Chi phí & quota' (KPI, thanh quota, biểu đồ ngày, top feature, CSV); platform_admin thấy `cost_usd` + `billable_usd`, tenant_admin chỉ số của tenant mình · hạn mức ngày: `GET/PUT /admin/tenants/:id/daily-limits` + reset, chỉ platform_admin (uploads/actions theo múi giờ tenant, ai_tokens theo UTC) · tenant-admin-scope: tenant_admin thấy usage rút gọn (lượt/token/%quota, không tiền; analytics/records/csv → 403) · NFR-03 báo cáo chi phí 1 tháng < 2 giây.

Cách ly & đóng băng: platform_admin đặt, tenant_admin đọc rút gọn tenant mình; có RLS. Không đóng băng.

Agent Hub — cấp agent cho tenant

Mục đích. Điểm giao giữa Admin và Hub về agent. *Dữ liệu thuộc schema `hub`; admin chỉ đọc / ghi qua API Hub.*

Thực thể: `hub.agent_grants`, `hub.agent_workflows` (Admin đọc `hub_ro`).

Luật chính: FR-37 trang group hiện agent được cấp + cho cấp agent cho group (ghi `hub.agent_grants` qua API Hub bằng JWT tenant_admin; Hub chỉ cho cấp agent đã entitlement cho tenant đó) · FR-13/15 workflow được agent dùng thì chặn xoá/tắt (đọc `hub.agent_workflows`) · FR-36 'Quyền hiệu lực' gồm cả agent · BR-13 quyền agent nằm ở agent-grant của Hub.

Phạm vi: luật entitlement agent × tenant và models thuộc BA Agent Hub / H4b-2 (ngoài ai-admin). Không đóng băng (`agents`, `agent-grants` là lõi chung).

Secrets

Mục đích. Lưu secret (app-key Dify) mã hoá; giá trị chỉ ghi, không đọc lại.

Bảng: `admin.secrets` (`name` unique, `ciphertext`, `iv`, `key_version`, `last4`, `note`, `updated_by`). Hub có bảng riêng `hub.secrets` (H4b-1) — không chung master key.

Luật chính: FR-50 CRUD (platform_admin); AES-256-GCM, master key `SECRET_MASTER_KEY` ở env (không trong DB) · BR-04 giá trị không bao giờ trả ra qua API/UI/export; `GET /admin/secrets` chỉ trả tên + last4 (AC-A06) · FR-51 audit chỉ ghi 'đã đổi' · FR-54 export chỉ ghi tên.

Cách ly & đóng băng: chỉ platform_admin; catalog toàn cục. Không đóng băng.

Audit / nhật ký

Mục đích. Truy vết ai sửa gì, khi nào; khôi phục bản trước.

Bảng `admin.audit_log`: `seq`, `at`, `tenant_id`, `actor_id`, `action`, `entity` (enum 12 giá trị), `entity_id`, `before`/`after` jsonb, `summary`, `snapshot`; append-only (trigger).

Luật chính: FR-51 mọi thay đổi cấu hình/user/group/quyền/quota ghi audit (secret chỉ 'đã đổi'); tenant_admin chỉ xem audit tenant mình · FR-52 khôi phục thực thể về trạng thái 'trước' (`POST /admin/audit/:id/restore`) · FR-55 chống ghi đè bằng `version` (409) · tenant-admin-scope: tenant_admin chỉ thấy audit user/group/grant/entitlement của tenant mình, bỏ `before`/`after`/`version`/file/`tenant_key`.

Cách ly & đóng băng: platform_admin thấy toàn bộ, tenant_admin rút gọn. Audit không đóng băng (export/import `transfer` đóng băng).

Định danh & SSO

Mục đích. Một nguồn định danh cho mọi gói; đăng nhập SSO giữa các app. *BA v0.4 ghi 'ngoài phạm vi' — đã lỗi thời; nguồn chuẩn: ADR-0018 + code.*

ADR-0018 (Accepted): admin-api là nguồn đăng nhập duy nhất (JWT EdDSA, JWKS); mgmt-app bỏ user/session riêng (org→tenant, owner/editor/viewer→group); SSO OIDC theo tenant (Google Workspace, Entra) ở GĐ2; MFA bắt buộc cho admin; Hub cấp token ngắn hạn cho tool MCP. Tiêu chí: đăng nhập một lần dùng mọi gói; tắt tài khoản ở IdP ⇒ mất quyền ⩽ 5 phút.

SSO nội bộ đã làm (spec sso-switch): `POST /auth/sso/code` tạo mã 32 byte sống 60 giây (SHA-256 trong Redis, dùng một lần) · `POST /auth/sso/redeem` đổi mã lấy phiên app đích (cookie riêng mỗi app `ai_rt_<app>`) · URL đích chỉ từ cấu hình build (không open redirect) · app switcher ở chat-web.

identity-import (N5): chuyển user mgmt-app sang admin-api (CLI, dry-run, lô 500, idempotent); `auth.legacy` verify scrypt rồi rehash sang argon2id (`LEGACY_HASH_SUNSET`).

Cách ly & đóng băng: token SSO gắn `tid/sub/sid/app`; sai công ty hoặc phiên nguồn đã logout đều 401. Không đóng băng.

Quy trình, Nguồn, Export/Import

Quy trình (Process Engine, ADM-FR-65..71). Trang 'Quy trình' + editor + run + token theo run. Dữ liệu thuộc schema `hub`; admin-web chỉ là giao diện (gọi thẳng Hub). Route editor admin dùng khi `HUB_PROCESS_ROUTES=admin`; nhóm route phục vụ chat-web đóng băng. ADM-FR-70 đã bỏ (CR-074).

Nguồn tham chiếu (ADM-FR-68/69). `git_remote`, `library`, `local_path`, nút 'Kiểm tra kết nối'. Hub `sources` và màn 'Nguồn' của admin-web **ĐÓNG BĂNG**.

Export/Import yaml (ADM-FR-54). Xuất/nhập workflow, command, feature, tenant, group, grant; nhập có bước xem diff; trần 5000 mỗi loại. Module `transfer` **ĐÓNG BĂNG**.

Tổng quan (Dashboard) & yêu cầu phi chức năng

Dashboard (BA §9). Màn Tổng quan khác nhau theo vai: số tenant, command, workflow, user, tenant vượt quota (module `overview`).

Phi chức năng & cách ly (ADM-NFR-01..07, AC-A01..A15): bảo mật (argon2id, JWT EdDSA, master key env, HTTPS, giới hạn IP/VPN cho API platform_admin) · lan truyền cấu hình ⩽ 5 giây (NFR-02) · CRUD < 300ms, báo cáo chi phí < 2s · Admin chết thì Hub vẫn chạy bằng cache + verify JWT (NFR-04) · **cách ly tenant ở tầng repository** (mọi truy vấn tenant_admin kẹp `tenant_id`, ngoài → 404) · chống ghi đè bằng `version` (FR-55, chéo mọi mảng). AC chính: AC-A01 (đăng nhập + khoá sau 5 lần), AC-A02 (khoá user ⇒ mất quyền ⩽ 15 phút), AC-A06 (secret không lộ).

Phần B — Cải tổ cấu hình & phân quyền (CR-107)

Hướng đang triển khai (spec draft, chưa Gate, chưa code; mã ADM-FR-76..85). Chi tiết nghiệp vụ + mock UI + sơ đồ luồng quyền ở các mục dưới; kiến trúc ở ADR-0033, spec `docs/specs/CR-107-admin-config-nesting`.

Mục tiêu & bối cảnh

Tài liệu cho đội phát triển: mô tả nghiệp vụ và ràng buộc để hiện thực việc cải tổ cấu hình ai-admin. Chi tiết kỹ thuật nằm ở ADR-0033 và spec `docs/specs/CR-107`.

Hiện trạng. Các màn cấu hình (ứng dụng, feature, người dùng, nhóm, phân quyền) nằm trải đều ở sidebar; muốn cấu hình một công ty phải nhảy qua nhiều màn, mỗi màn tự chọn lại công ty. Quyền đọc/ghi đang ẩn trong khái niệm "feature" kỹ thuật, khó hiểu với người vận hành.

Mục tiêu. (1) Gom cấu hình theo ngữ cảnh công ty (tenant); (2) trình bày quyền bằng ngôn ngữ vai + đọc/ghi; (3) giữ nguyên cách ly tenant và điểm chặn quyền đang chạy ở backend.

Mô hình tổng thể

Ba trục, tách bạch:

- **Ứng dụng gán theo công ty.** Mỗi công ty (tenant) được bật các ứng dụng/gói nghiệp vụ cần dùng (Hợp đồng, Community, Chat AI…). Bật = cấp quyền dùng cho công ty đó.
- **Điều hướng lồng.** Sidebar trái chỉ liệt kê tên công ty + "Thêm công ty". Chọn một công ty → mở workspace bên phải, trong đó có tab: Tổng quan · Ứng dụng & Gói · Phân quyền · Người dùng · Chi phí & quota. Danh mục dùng chung (định nghĩa ứng dụng, feature) vẫn ở cấp Nền tảng, tách khỏi công ty.
- **Quyền 3 tầng.** ① vai hệ thống (toàn admin) · ② vai theo app (đọc/ghi) · ③ gán người dùng vào vai — chi tiết ở mục Phân quyền.

Phân quyền — vai theo app

Quyền chia 3 tầng, không trộn:

1. **Vai hệ thống** — `platform_admin` / `tenant_admin` / `member`. Gán ở hồ sơ người dùng, quyết quyền quản trị. Không nằm trong màn phân quyền.
2. **Vai theo app** — mỗi vai thuộc đúng một ứng dụng, mang một mức quyền. Mỗi app khi bật có sẵn 3 vai mặc định; tạo thêm vai tuỳ biến được.
3. **Gán người dùng vào vai** — một người có thể giữ vai ở nhiều app; quyền thực tế tính theo từng app.

Số vai hiện tại: **3 vai hệ thống** (cố định) + **3 vai mặc định cho mỗi app nghiệp vụ** (Chủ sở hữu / Biên tập / Người xem). Công ty bật 2 app ⇒ 3 + 6 vai.

Mức quyền (vai)	Ý nghĩa	Tương ứng kỹ thuật
Đọc	Xem, không sửa	read
Đọc + Ghi	Xem và chỉnh sửa	read + write
Quản trị	Toàn quyền trong app	read + write + admin

Luồng onboard công ty

"Thêm công ty" mở một wizard liền mạch:

1. **Thông tin công ty** — tên, mã (cố định sau khi tạo), múi giờ; tạo tài khoản quản trị đầu tiên (tenant_admin).
2. **Gán ứng dụng** — chọn từ ứng dụng có sẵn; bật = cấp cho công ty.
3. **Phân quyền** — mỗi app bật sẵn 3 vai mặc định; chỉnh hoặc thêm vai nếu cần.
4. **Người dùng** — tạo tài khoản và gán vai.

Wizard dùng cho lần đầu; về sau sửa từng phần trong tab của workspace công ty (cùng dữ liệu, cùng endpoint).

Ranh giới & cách ly

Nguyên tắc: chỉ lồng vào công ty những cấu hình thuộc một công ty (có cách ly theo tenant); danh mục dùng chung giữ ở Nền tảng.

Cấu hình	Phạm vi	Nơi đặt	Ai sửa
Định nghĩa ứng dụng / feature / command	Dùng chung	Nền tảng	platform_admin
Gán ứng dụng/gói cho công ty	Theo tenant	Trong công ty	platform_admin
Phân quyền (vai + đọc/ghi)	Theo tenant	Trong công ty	platform_admin · tenant_admin
Người dùng, nhóm	Theo tenant	Trong công ty	platform_admin · tenant_admin

Cấu hình	Phạm vi	Nơi đặt	Ai sửa
Quota	Theo tenant	Trong công ty	platform_admin

Cách ly bắt buộc:

- **User đối tác (external / Community):** KHÔNG cho tạo vai tuỳ biến; đối tác chỉ có 2 mức tĩnh đọc/ghi hiện hành. Giữ cách ly đối tác (không thấy dữ liệu nội bộ).
- **Chat AI, Studio, Admin KHÔNG có "vai theo app":** Chat AI chỉ bật/tắt theo công ty; Studio/Admin theo vai hệ thống. Màn phân quyền không hiển thị "tạo vai" cho các app này (tránh quyền ảo).

Ảnh hưởng xuyên app

Quyền vẫn được thực thi ở nơi cũ (feature-grant); việc đổi sang "vai" chỉ là lớp trên, nên với các gói nghiệp vụ là trong suốt.

App	Lấy quyền thế nào	Ảnh hưởng	Lưu ý
Hợp đồng (SHT)	Đọc quyền đọc/ghi/quản trị của gói contracts	Trong suốt	Phải cấp đủ quyền đọc thì app mới hiện
Community	Như trên; đối tác dùng 2 mức tĩnh	Trong suốt	Không cấp quyền chéo cho đối tác
Chat AI	Chỉ bật/tắt theo công ty	Không áp dụng vai	Dock "Sổ Hợp Tác" trong chat mở theo quyền đọc contracts
Knowledge	Có 3 vai nhưng chưa có màn tiêu thụ rõ	Trong suốt	Chưa hứa đủ 3 mức tới khi có app dùng
Studio / Admin	Theo vai hệ thống	Không áp dụng vai	Không phải gói nghiệp vụ

Ràng buộc kỹ thuật cho đội dev

Mô hình "vai" là nguồn ở tầng admin; khi lưu, hệ thống biên dịch một chiều xuống lớp cấp quyền đang chạy (nhóm + feature-grant). Điểm chặn quyền ở backend không đổi. Bốn ràng buộc bắt buộc:

- **R1 — đủ cả 3 quyền, không bao hàm nhau:** Đọc ⇒ cấp quyền đọc; Đọc+Ghi ⇒ cấp cả đọc và ghi; Quản trị ⇒ cả ba. Thiếu quyền đọc thì app báo "không có quyền" và ẩn khỏi launcher.
- **R2 — cấp qua nhóm (group), không gán thẳng cho người dùng** (backend bỏ qua quyền gán lẻ cho user).
- **R3 — phát tín hiệu làm mới sau khi biên dịch** để backend nạp lại quyền (quên ⇒ quyền đổi nhưng chưa có hiệu lực).
- **R4 — "vai theo app" chỉ cho gói nghiệp vụ** (Hợp đồng/Community/Knowledge); Chat/Studio/Admin loại khỏi UI phân quyền.

Backfill (dữ liệu hiện có). Nhận 3 nhóm vai sẵn có thành vai mặc định; nhóm đã bị sửa tay lệch chuẩn sẽ ép về chuẩn. Vì đổi quyền hiệu lực của khách, bắt buộc: chạy thử (dry-run) + báo cáo công ty/nhóm sẽ đổi + xác nhận thủ công ở production + ghi audit từng thay đổi.

Liên quan Community-unify (CR-106). Chỉ số "quyền hợp đồng" (caps.contracts) phải tính từ quyền gói hiện có, không đọc bảng vai mới — tránh hai nguồn quyền. Đối tác luôn "không có quyền".



Luồng quyền: vai admin → biên dịch → feature-grant → backend

Lưu vai → biên dịch → nhóm + feature-grant → backend đọc như cũ; nên chuyển sang vai là trong suốt với app.

Giao diện (mock)

Mock tương tác (4 màn, nhãn tiếng Việt, có sáng/tối): mở mock UI

- **Khái niệm & nav** — so sánh trải-đều vs lồng; bảng cái gì lồng được / không.
- **Wizard onboard** — 4 bước; luồng tạo công ty.
- **Workspace công ty** — tab Ứng dụng & Gói (bật/tắt app) và các tab khác.
- **Phân quyền** — vai theo từng app (3 mức), tạo vai, gán người dùng; panel kiểm tra quyền.

Trạng thái cần dựng khi code (chưa có trong mock): đang tải, rỗng, lỗi tải, không đủ quyền.

Bản đồ màn hình ↔ nghiệp vụ

Màn (mock)	Nghiệp vụ (Phần A)	Page admin thực
Điều hướng lồng	Tenant, Quyền, cách ly	shell/nav (`nav.ts`)
Wizard onboard	Tenant + Ứng dụng & gói + Quyền + Người dùng	(mới) + `/tenants` , `/users`
Workspace công ty	Ứng dụng & gói, Người dùng, Quota	`/tenants/$id` (các tab)
Phân quyền (RBAC)	Mô hình quyền	`/access` , `/groups` (hiện tại)

Màn 1 — Điều hướng lồng (shell + sidebar)

Mục đích. Một vỏ; chọn công ty rồi cấu hình trong ngữ cảnh đó.

Thành phần. Sidebar trái (248px) 3 nhóm: **Nền tảng** (Ứng dụng, Features, Agents — chỉ platform_admin) · **Công ty (tenant)** = danh sách tên công ty + 'Thêm công ty' · **Hệ thống** (Secrets, Nhật ký). Topbar 60px: breadcrumb, badge 'Nền tảng', chuông, avatar. Click tên công ty → mở workspace; bộ tab ở container phải.

Vai. platform_admin thấy đủ; tenant_admin chỉ thấy công ty mình (không có nhóm Nền tảng).

Nghiệp vụ. Tenant, Người dùng, Nhóm, Quyền; ranh giới global vs tenant.

Trạng thái. Nhiều công ty → cuộn/tìm; đang tải danh sách; chưa có công ty (platform mới dựng).

Màn 2 — Wizard 'Onboard công ty'

Mục đích. Tạo + cấu hình công ty mới trong một luồng.

Bước. 1 Thông tin (tên, mã cố định, múi giờ, tạo tenant_admin đầu — createFirstAdmin) · 2 Gán ứng dụng (bật gói có sẵn = entitlement; Community kèm cảnh báo đối tác) · 3 Phân quyền (mỗi app 3 vai mặc định) · 4 Người dùng (tạo + gán vai).

Vai. platform_admin (tạo tenant, gán app/entitlement); phần grant/user có thể tenant_admin làm sau.

Nghiệp vụ. Tenant (FR-60), Ứng dụng & gói (enablePack), Mô hình quyền, Người dùng (FR-04/60).

Trạng thái. Mã công ty trùng → lỗi; bước 3/4 bỏ qua được (Q8); bật Community → nhắc kiểm cách ly HT-75/76. Wizard = lần đầu; về sau sửa ở workspace.

Màn 3 — Workspace công ty

Mục đích. Sửa cấu hình một công ty về sau (không qua wizard).

Thành phần. Header: tên + badge trạng thái (Đang hoạt động/Đã khoá) + nút Khoá / Onboard lại. Tabs: **Tổng quan** · **Ứng dụng & Gói** (bảng: Ứng dụng | Khoá | Trạng thái Đang bật/Chưa bật | Vai đã tạo | switch bật/tắt) · **Phân quyền** · **Người dùng** · **Chi phí & quota**.

Vai. platform_admin đủ; tenant_admin: Người dùng / Phân quyền / Quota (rút gọn, theo tenant mình).

Nghiệp vụ. Tab → Phần A: Ứng dụng & gói, Mô hình quyền, Người dùng, Quota. Tương đương page thực `/tenants/$id`.

Trạng thái. Community bật kèm cảnh báo đối tác; trong mock các tab Tổng quan/Người dùng/Quota chưa dựng nội dung.

Màn 4 — Phân quyền (RBAC)

Mục đích. Gán quyền đọc/ghi theo vai, theo từng app.

Thành phần. Callout 3 tầng · **Vai theo ứng dụng** (mỗi app một khối: bảng Vai | Mức quyền | Người | Sửa + nút 'Tạo vai') · **Gán người dùng vào vai** (Người dùng | Vai hệ thống | Vai theo app | Quyền thực tế) · **Kiểm tra quyền** · ghi chú kiến trúc (biên dịch xuống feature-grant).

Vai. platform_admin + tenant_admin (trong tenant).

Nghiệp vụ. Mô hình quyền (Phần A) + ADR-0033 (R1–R4). External: không tạo vai; Chat/Studio/Admin: không có vai. Tương đương page thực `/access` + `/groups`.

Trạng thái. Badge 'chưa lưu'; vai mặc định vs tuỳ biến; đang tải; lỗi tải; không đủ quyền.

Quyết định đã chốt & liên kết

Chủ đề	Quyết định
Nav	Sidebar = tên công ty; workspace có tab
Tạo công ty	Wizard onboard (bước 1 = thông tin + admin đầu)
Quyền	3 tầng; vai theo app; 3 mức Đọc/Ghi/Quản trị
Vai	3 mặc định mỗi app + tạo vai tuỳ biến
External	Cấm vai tuỳ biến; 2 mức tĩnh đọc/ghi
Backfill	Ép về chuẩn + dry-run/xác nhận/audit
Kiến trúc	Vai → biên dịch xuống feature-grant; backend không đổi

Liên kết. ADR-0033 (kiến trúc RBAC) · spec repo `docs/specs/CR-107-admin-config-nesting` · mock UI.